

Incident Response Plan

Document ID: GOYA-IRP-001 **Version:** 1.0 **Status:** Draft **Last Updated:** 2026-08-05 **Owner:** Security Officer

1. Purpose

This plan defines Goya Ledger’s response to security incidents affecting the PKI, TSA, OCSP, or signing infrastructure. It fulfills ETSI TS 102 042 §7.4.8 and Chilean DS 181 requirements for accredited PSC operations.

2. Scope

Covers all incidents affecting: - CA key compromise or unauthorized access - TSA service disruption or time source failure - OCSP responder unavailability - Subscriber identity fraud or proofing failures - Audit log tampering or loss - Unauthorized certificate issuance - System intrusion or data breach

3. Severity Classification

Level	Description	Response Time	Escalation
P1 — Critical	CA key compromise, mass certificate mis-issuance	Immediate (< 1 hour)	Security Officer + CEO + Entidad Acreditadora
P2 — High	TSA/OCSP outage > 1 hour, single cert mis-issuance	< 4 hours	Security Officer + CTO
P3 — Medium	Audit log integrity failure, RA process violation	< 24 hours	Security Officer
P4 — Low	Failed login attempts, minor policy deviation	< 72 hours	Operations team

4. Incident Response Team

Role	Responsibility	Contact
Security Officer	Leads response, coordinates communications	security@goya.cl
PKI Administrator	CA operations, certificate revocation, CRL publication	pki@goya.cl
System Administrator	Infrastructure, logs, network isolation	ops@goya.cl
Legal Counsel	Regulatory notification, subscriber communication	legal@goya.cl
Communications Lead	External communications, subscriber notifications	comms@goya.cl

5. Response Procedures

5.1 Detection and Reporting

1. Automated monitoring detects anomaly (audit log alerts, health checks)
2. Any team member can report via security@goya.cl or emergency phone
3. Security Officer acknowledges within **72 hours** (P4) to **1 hour** (P1)
4. Incident logged in audit system with AuditAction::SecurityOfficerLogin

5.2 Triage and Classification

1. Security Officer assesses severity (P1–P4)
2. Assigns incident ID: INC-YYYY-NNNN
3. Activates response team per severity level
4. Documents initial assessment in incident record

5.3 Containment

P1 — CA Key Compromise: - Immediately revoke all certificates issued by the compromised CA - Publish emergency CRL within 1 hour - Suspend OCSP responder for compromised CA - Notify Entidad Acreditadora (Subsecretaría de Economía) - Activate backup CA from key ceremony custodian shares

P2 — Service Outage: - Failover to backup infrastructure - Restore from latest checkpoint/snapshot - Monitor for recurrence

P3 — Audit/RA Violation: - Suspend affected RA officer account - Quarantine affected identity proofing records - Review audit chain integrity via verify_audit_chain()

5.4 Eradication

1. Identify root cause through forensic analysis (src/forensic.rs)

2. Remove threat actor access
3. Patch vulnerability if applicable
4. Rebuild affected systems from known-good state

5.5 Recovery

1. Restore services in order: CA → CRL → OCSP → TSA → RA
2. Verify audit log chain integrity
3. Issue replacement certificates if revoked
4. Confirm NTP synchronization via `NtpTimeSource::validate()`
5. Run full system health check

5.6 Post-Incident

1. Complete incident report within **7 days**
2. Conduct root cause analysis (RCA)
3. Update this plan if gaps identified
4. Brief stakeholders and subscribers
5. File regulatory notification if required by Ley 19.799

6. Communication Plan

Audience	Channel	Timeline
Entidad Acreditadora	Email to <code>oficinadepartesgd@economia.cl</code>	Within 24 hours (P1/P2)
Affected subscribers	Email + portal notification	Within 48 hours
General public	Website notice	Within 72 hours (if material)
Internal team	Secure channel	Immediate

7. Testing

- **Tabletop exercise:** Quarterly (simulated P1 scenario)
- **Technical drill:** Semi-annually (actual failover test)
- **Plan review:** Annually or after any P1/P2 incident

8. Regulatory References

- ETSI TS 102 042 §7.4.8 — Incident management
- Ley 19.799 — Obligations of PSC
- DS 181/2002 — Reglamento
- Decreto 24/2019 — Norma Técnica FEA
- ISO 27001:2022 Annex A.16 — Information security incident management
- NIS2 Directive (EU 2022/2555) Art. 23 — Incident notification
- CIR 2025/2160 — Risk management for trust service providers

9. NIS2 Incident Notification (Art. 23)

Trust service providers classified as essential entities under NIS2 must notify:

Stage	Deadline	Recipient	Content
Early warning	24 hours from awareness	National CSIRT + ENISA	Whether incident is suspected malicious or cross-border
Incident notification	72 hours from awareness	National CSIRT + ENISA	Severity, impact, IoCs, initial assessment
Intermediate report	Upon request	National CSIRT	Status update
Final report	1 month after notification	National CSIRT + ENISA	Root cause, mitigation, cross-border impact

For significant incidents affecting trust service users: - Notify affected users without undue delay (Art. 23(1)) - Include mitigation guidance in user notification

See also: SECURITY.md §Vulnerability Disclosure for CRA-specific reporting.

10. Document Control

Version	Date	Author	Changes
1.1	2026-08-31	Security Officer	NIS2 Art. 23 notification SLAs, CIR 2025/2160 reference
1.0	2026-08-05	Security Officer	Initial draft